TASK 6

COMPREHENSIVE PENETRATION TESTING & VULNERABILITY ASSESSMENT REPORT

Cybersecurity Capstone • Executive Committee Edition

Prepared by
S Tejo Lakshman

Assessment Date
18 September 2026

Authorized Security Laboratory Assessment
Formal Mentor Review Deliverable

Classification: Training / Confidential — Authorized Lab

Document Control & Confidentiality

Field	Value
Document	Task 6 — Comprehensive Penetration Testing & Vulnerability Assessment Report
Assessment Type	Authorized Security Laboratory VAPT / Capstone
Prepared By	S Tejo Laakshman
Assessment Date	18 September 2026
Version	1.0
Classification	Training / Confidential — Authorized Lab
Intended Audience	Mentor / Executive Committee / Security Training Review

Evidence statement: Command outputs and screenshots in this report are representative laboratory evidence generated for the capstone workflow. They are not claims of unauthorized testing against real third-party infrastructure.

Table of Contents

1. Executive Summary
2. Objectives and Scope
3. Rules of Engagement
4. Methodology
5. Asset Inventory & Attack Surface
6. Reconnaissance & Enumeration
7. Risk Assessment & CVSS 3.1
8. OWASP Mapping
9. Technical Findings
10. Prioritized Remediation
11. Developer Patch Guidelines
12. Sysadmin Hardening
13. Verification & Retesting
14. Residual Risk & Conclusion
15. Appendix & Submission Checklist

1. Executive Summary

This Task 6 capstone consolidates an authorized security assessment into a formal Penetration Testing and Vulnerability Assessment (VAPT) report. The assessment follows a controlled workflow covering reconnaissance, host discovery, service enumeration, vulnerability identification, safe validation, risk assessment, remediation planning, and retesting.

The report is structured for executive review: technical observations are translated into business-relevant impact, mapped to CVSS 3.1 and OWASP categories, and paired with time-bound remediation guidance.

Executive Risk Snapshot

Finding	Severity	CVSS 3.1	Primary Theme	Target
F-01	High	7.5	Excessive service exposure	0–7 days
F-02	High	8.1	Authentication weakness	0–7 days
F-03	High	8.6	Injection / input handling	0–7 days
F-04	Medium	6.5	Secret management	8–30 days
F-05	Medium	5.3	Logging & monitoring	8–30 days

Executive action: assign owners, implement corrective controls within target windows, preserve remediation evidence, and perform a controlled retest before closure.

Key Management Takeaways

• Reduce the reachable attack surface to only required services.

• Strengthen authentication and session controls.

• Use parameterized queries and safe input/output handling.

• Move secrets out of source/configuration files and rotate when exposure is suspected.

• Centralize security logging and define alerts for authentication and high-risk application events.

2. Assessment Objectives & Scope

Objectives

• Identify security weaknesses in explicitly authorized laboratory assets.

• Determine likely attack paths without exceeding approved scope.

• Document reproducible evidence for confirmed or representative findings.

• Map findings to CVSS 3.1 and relevant OWASP Top 10 categories.

• Provide developer and sysadmin remediation instructions.

• Define verification and retesting.

Authorized Scope

Asset	Environment	Status	Restrictions
LAB-01	Local training web app / isolated	Allowed	No DoS; no third-party scanning
LAB-02	Deliberately vulnerable VM / host-only	Allowed	No persistence; no outbound traffic
Tester workstation	Assessment source	Allowed	Testing traffic only

Out of Scope

• Public Internet targets without written authorization.

• Third-party infrastructure.

• Denial-of-service or destructive testing.

• Persistence, lateral movement, or unauthorized outbound traffic.

• Real credentials, personal data, or production secrets.

3. Rules of Engagement

All testing activities must be performed only within written authorization. Authorization should identify the asset owner, approved addresses, permitted techniques, test window, evidence rules, emergency contact, and stop conditions.

Operating Rules

• Use only approved hosts, applications, accounts, and networks.

• Keep scans and validation inside the authorized window.

• Prefer non-destructive validation and minimum-impact test cases.

• Capture screenshots and command output with timestamps or test identifiers.

• Redact passwords, tokens, private keys, personal information, and sensitive identifiers.

• Immediately stop and report if unexpected systems or data become accessible.

Stop Conditions

• Unexpected impact to a non-target asset.

• Service instability or data-integrity concerns.

• Evidence of access beyond the authorized boundary.

• Instruction from the asset owner or mentor to stop.

Evidence Handling

Evidence should be stored in an access-controlled location with filenames identifying the finding and test step. Public repositories should contain only sanitized evidence.

4. Methodology

Phase	Activities	Deliverable
Reconnaissance	Review scope, assets, hostnames, applications and assumptions.	Scope baseline
Host Discovery	Identify live hosts in approved range.	Host inventory
Service Enumeration	Identify ports, protocols, services and versions.	Service inventory
Vulnerability Identification	Review versions, configurations and application behavior.	Candidate findings
Validation	Safely confirm security impact within scope.	Evidence
Risk Assessment	Assign severity, CVSS metrics and OWASP mapping.	Risk register
Remediation	Define owner, action and target date.	Remediation plan
Retesting	Repeat safe test and verify controls.	Closure evidence

Assessment Flow

Scope → Discover → Enumerate → Identify → Validate → Score → Remediate → Retest → Close

Testing Principles

• Least-impact testing.

• Reproducibility.

• Evidence-based findings.

• Clear separation of observed evidence and illustrative examples.

• No unsupported claim of production compromise.

5. Asset Inventory & Attack Surface

Asset ID	Asset Name	Environment	Address / URL	Allowed	Excluded
LAB-01	Local training web app	RabTech lab	http://127.0.0.1:8080	Yes	DoS; third-party scanning
LAB-02	Deliberately vulnerable VM	RabTech lab	192.168.56.20	Yes	Persistence; outbound traffic

Attack Surface

• Web application and HTTP service.

• Network services on the deliberately vulnerable VM.

• Authentication endpoints and session management.

• Application-to-database communication.

• Administrative interfaces reachable from the approved test network.

Trust Boundaries

Boundary	Security Concern
Tester → Lab	Only authorized traffic should cross the boundary.
Web → Application	Untrusted input must be validated and safely processed.
Application → Database	Queries should use least privilege and parameterization.
Identity → Session	Authentication and session tokens require secure lifecycle controls.
Application → Secrets	Credentials/keys must be protected and access-controlled.

6. Reconnaissance, Host Discovery & Enumeration

The following sanitized command outputs are generated as capstone sample evidence to demonstrate the expected evidence format. They should be treated as lab evidence examples, not as scans of an external system.

6.1 Host Discovery — Sample Output

```
$ nmap -sn 192.168.56.0/24
Nmap scan report for 192.168.56.20
Host is up (0.00041s latency).
MAC Address: 08:00:27:XX:XX:XX (Oracle VirtualBox)
Nmap done: 256 IP addresses (1 host up)
```

6.2 TCP SYN Scan — Sample Output

```
$ sudo nmap -sS 192.168.56.20
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3306/tcp open  mysql
Nmap done: 1 IP address (1 host up)
```

6.3 Service / Version Detection — Sample Output

```
$ sudo nmap -sV 192.168.56.20
22/tcp   open  ssh       OpenSSH 8.2p1
80/tcp   open  http      Apache httpd 2.4.49
139/tcp  open  netbios-ssn Samba
445/tcp  open  microsoft-ds Samba
3306/tcp open  mysql     MySQL 5.7.x
```

6. Reconnaissance — Continued

6.4 UDP Scan — Sample Output

```
$ sudo nmap -sU --top-ports 20 192.168.56.20
PORT      STATE          SERVICE
53/udp    open           domain
67/udp    open|filtered dhcps
123/udp   open           ntp
161/udp   open|filtered snmp
Nmap done: 1 IP address (1 host up)
```

6.5 OS Detection — Sample Output

```
$ sudo nmap -O 192.168.56.20
Device type: general purpose
Running: Linux
OS  details:  Linux  5.x
Network Distance: 1 hop
```

6.6 Web Header Review — Sample Output

```
$ curl -I http://127.0.0.1:8080
HTTP/1.1 200 OK
Server: Apache/2.4.49
Content-Type: text/html; charset=UTF-8
X-Content-Type-Options: nosniff
```

Important: If your real lab outputs differ, replace these samples with the real outputs and screenshots. Do not represent sample values as observations from a different system.

7. Risk Assessment & CVSS 3.1

CVSS 3.1 Base Scores communicate technical severity. They do not replace business context such as asset criticality, exposure, compensating controls, or data sensitivity.

ID	Finding	Vector	Score	Severity
F-01	Excessive service exposure	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	7.5	High
F-02	Weak authentication controls	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N	8.1	High
F-03	Injection / input validation	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H	8.6	High
F-04	Secret management weakness	CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N	6.5	Medium
F-05	Insufficient security logging	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N	5.3	Medium

Scoring note: The vectors are illustrative capstone scoring examples. Final mentor submission should use vectors calculated from the exact confirmed technical characteristics of the actual findings.

Risk Matrix

Likelihood / Impact	Low	Medium	High
Low	Low	Low	Medium
Medium	Low	Medium	High
High	Medium	High	Critical

8. OWASP Top 10 Mapping

Finding	OWASP Top 10 Category	Control Focus
F-01	A05:2021 Security Misconfiguration	Disable unnecessary services; restrict exposure; harden defaults.
F-02	A07:2021 Identification and Authentication Failures	Strong authentication, secure sessions, rate limiting, MFA where appropriate.
F-03	A03:2021 Injection	Parameterized queries, safe APIs, allow-list validation and output encoding.
F-04	A02:2021 Cryptographic Failures	Protect secrets and keys; use approved cryptographic mechanisms.
F-05	A09:2021 Security Logging and Monitoring Failures	Centralize logs, protect integrity, alert on security events.

Framework Interpretation

OWASP categories describe the class of application security weakness. CVSS describes technical severity. A finding can therefore have both an OWASP category and a CVSS score without the two being interchangeable.

Control Themes

• Minimize attack surface.

• Protect identity and session boundaries.

• Treat external input as untrusted.

• Protect secrets throughout their lifecycle.

• Make security events observable and actionable.

9. Detailed Technical Findings — F-01 & F-02

F-01 — Excessive Service Exposure

Description: Multiple network services are reachable on the authorized lab host. Services not required for intended function create additional attack surface.

Evidence: See sample Nmap TCP/UDP enumeration in Sections 6.2–6.4. Replace with actual authorized scan output for final evidence.

Impact: Additional reachable services can expose vulnerable versions, weak configurations, or unnecessary authentication surfaces.

CVSS: 7.5 High — illustrative vector shown in Section 7.

OWASP: A05:2021 Security Misconfiguration.

Remediation: Disable unused services; restrict administrative services to trusted management networks; enforce host firewall rules; document required ports.

F-02 — Weak Authentication Controls

Description: Authentication controls may be susceptible to password guessing, weak password policy, inadequate rate limiting, or insecure session lifecycle handling.

Evidence: Application authentication test cases and sanitized screenshots should be attached here for the actual lab.

Impact: Successful abuse may result in unauthorized account access and access to protected functionality.

CVSS: 8.1 High — illustrative vector shown in Section 7.

OWASP: A07:2021 Identification and Authentication Failures.

Remediation: Use strong password hashing, rate limiting, secure session expiration, appropriate MFA, and protective controls for repeated authentication failures.

9. Detailed Technical Findings — F-03 to F-05

F-03 — Injection / Input Validation Risk

Description: Untrusted input reaching database queries, interpreters, templates, or operating-system commands without safe handling can create injection risk.

Impact: Depending on the vulnerable sink and privileges, successful exploitation can affect confidentiality, integrity, or availability.

CVSS: 8.6 High — illustrative. **OWASP:** A03:2021 Injection.

Remediation: Parameterize queries, validate inputs with allow-lists where practical, encode outputs by context, and avoid shell execution of raw user input.

F-04 — Secret Management Weakness

Description: Credentials, API keys, tokens, or private keys stored in source code or broadly accessible configuration files can be exposed.

Impact: Secret disclosure can enable unauthorized access or compromise cryptographic trust.

CVSS: 6.5 Medium — illustrative. **OWASP:** A02:2021 Cryptographic Failures.

Remediation: Use secrets management, least-privilege access, rotation, secure CI/CD variables, and repository secret scanning.

F-05 — Insufficient Security Logging

Description: Fragmented or missing security logs reduce detection and investigation capability.

Impact: Security events may remain undetected longer and incident reconstruction may be incomplete.

CVSS: 5.3 Medium — illustrative. **OWASP:** A09:2021 Security Logging and Monitoring Failures.

Remediation: Centralize logs, synchronize system time, protect log integrity, define alert rules, and review authentication/security events.

10. Prioritized Remediation Plan

Priority	Timeline	Action	Owner	Closure Evidence
P1	0–7 days	Disable unnecessary services and restrict management ports.	Sysadmin	Service/firewall output
P1	0–7 days	Fix confirmed authentication/injection weaknesses.	Developers	Test cases + screenshots
P1	0–7 days	Rotate exposed credentials/keys where applicable.	Security/Sysadmin	Rotation record
P2	8–30 days	Harden sessions, input validation and secure configuration.	Developers	Automated/manual tests
P2	8–30 days	Centralize logging and implement alerting.	Security/Sysadmin	SIEM/log evidence
P3	31–90 days	Implement recurring scanning and security regression tests.	Engineering/Security	Pipeline/report evidence

Remediation Workflow

Assign owner → Create ticket → Patch/change → Test → Evidence capture → Retest → Close or accept residual risk

Ownership Model

• Developers: application logic, authentication, validation, secrets integration and regression tests.

• Sysadmins: service exposure, firewall, OS patching, access restrictions and logging infrastructure.

• Security: validation, risk register, retesting and evidence quality.

• System/business owner: residual-risk acceptance when remediation cannot be completed immediately.

11. Developer Patch Guidelines

Step 1 — Replace Unsafe Query Construction

```
Before:
query = "SELECT * FROM users WHERE name='" + user_input + "'"

After:
cursor.execute("SELECT * FROM users WHERE name = %s", (user_input,))
```

Use parameterized database APIs. Do not concatenate untrusted input into SQL statements.

Step 2 — Strengthen Authentication

• Use Argon2id or bcrypt-class password hashing with current recommended configuration.

• Enforce appropriate password policy without storing plaintext passwords.

• Add rate limiting and monitoring for repeated authentication failures.

• Use secure, random session identifiers and expire sessions appropriately.

• Use MFA for sensitive administrative or high-value actions where appropriate.

Step 3 — Protect Secrets

• Remove secrets from source code and public repositories.

• Load secrets through environment/secret-management mechanisms.

• Rotate secrets after suspected exposure.

• Use separate credentials for development, testing and production.

Step 4 — Security Regression Tests

• Test invalid input handling.

• Test authorization boundaries with multiple roles.

• Test repeated failed-login behavior.

• Test that secrets are not included in logs or API responses.

12. Sysadmin Hardening Guidelines

Step 1 — Reduce Network Exposure

```
# Run only on the authorized lab host
sudo ss -tulpen
sudo ufw status verbose
sudo systemctl --type=service --state=running
```

• Disable services not required by the approved baseline.

• Restrict SSH/RDP/administrative interfaces to trusted networks.

• Use host firewall rules to permit only required traffic.

• Document every exposed port and its technical purpose.

Step 2 — Patch and Harden

• Apply OS and application security updates through the approved change process.

• Remove unsupported software where feasible.

• Use least-privileged service accounts.

• Disable default accounts or change default credentials according to platform guidance.

Step 3 — Logging and Monitoring

• Centralize authentication and security logs.

• Synchronize system clocks.

• Protect logs against unauthorized alteration.

• Alert on repeated authentication failures, privilege changes and suspicious service changes.

Step 4 — Backup and Recovery

• Maintain tested backups appropriate to the application.

• Document recovery steps.

• Verify backups do not expose credentials or private keys.

13. Verification & Retesting Plan

Step	Activity	Pass Criteria	Evidence
1	Confirm change	Approved patch/configuration exists.	Change/ticket record
2	Repeat original test	Original vulnerable behavior not reproduced.	Updated scan/test
3	Negative test	Invalid/malicious test case is safely rejected.	Screenshot/output
4	Adjacent-control check	No obvious regression introduced.	Configuration/log evidence
5	Risk update	Finding marked Closed or Residual Risk.	Risk register

Retest Examples

```
# Service exposure
nmap -sV 192.168.56.20

# Web headers
curl -I http://127.0.0.1:8080

# Local listening services
sudo ss -tulpen
```

Retesting should reproduce original conditions as closely as practical. A finding should not be marked closed solely because a configuration changed; security behavior should be demonstrated.

Closure States

• Closed — remediation verified.

• Partially Remediated — risk reduced but condition remains.

• Accepted Residual Risk — owner explicitly accepts remaining exposure.

• Open — remediation not completed or verification failed.

14. Residual Risk & Executive Conclusion

Residual risk remains whenever an asset retains exposure, an application control has limitations, or remediation is deferred. Residual-risk decisions should consider technical severity, asset criticality, exposure, compensating controls, and operational requirements.

Conclusion

This capstone demonstrates an end-to-end VAPT reporting process from authorized scope definition through discovery, enumeration, risk mapping, remediation, and retesting. The report provides an executive-level structure while retaining technical evidence suitable for mentor review.

The operational cycle is: identify → prioritize → remediate → verify. Public evidence should be sanitized so that no credentials, tokens, private keys, personal data, or sensitive infrastructure details are disclosed.

Final Submission Checklist

- ■ Formal 15–20 page VAPT PDF completed.
- ■ Task 6 label included.
- ■ Executive summary and objectives included.
- ■ Authorized scope and ROE included.
- ■ Asset inventory and attack surface documented.
- ■ Nmap/enumeration evidence included.
- ■ CVSS 3.1 matrix and OWASP mapping included.
- ■ Technical findings include impact and remediation.
- ■ Developer and sysadmin patch guidance included.
- ■ Retesting and residual-risk process included.
- ■ GitHub Security Lab repository prepared.
- ■ Public repository contains no secrets or sensitive evidence.

15. Appendix — Evidence Pack & GitHub Repository

A. Recommended Evidence File Names

File	Purpose
01_scope_authorization.png	Authorized scope / ROE evidence
02_host_discovery.txt	Host discovery output
03_tcp_syn_scan.txt	TCP SYN scan output
04_udp_scan.txt	UDP scan output
05_service_version_scan.txt	Service/version output
06_os_detection.txt	OS detection output
07_wireshark_capture.png	Packet capture evidence
F01_service_exposure.png	F-01 evidence
F02_authentication.png	F-02 evidence
F03_input_validation.png	F-03 evidence
retest_after_patch.png	Post-remediation verification

B. GitHub Repository Structure

```
security-lab-capstone/
■■■ README.md
■■■ reports/
■   ■■■ Task_6_Comprehensive_VAPT_Report.pdf
■■■ evidence/
■■■ scans/
■■■ remediation/
■■■ docs/
    ■■■ scope.md
    ■■■ rules-of-engagement.md
```

C. Suggested GitHub README Description

Task 6 — Comprehensive Penetration Testing & VAPT Capstone
Authorized security laboratory assessment covering reconnaissance, host discovery, service enumeration, vulnerability assessment, CVSS 3.1 risk analysis, OWASP mapping, technical findings, remediation guidance, and retesting. Evidence is sanitized for public sharing.

D. Public Repository Safety

• Never publish passwords, API tokens, SSH private keys, database credentials, cookies or session tokens.

• Redact sensitive IPs/hostnames if the lab owner requires it.

• Remove personal data from screenshots.

• Keep raw sensitive evidence private and publish sanitized copies.

End of Task 6 Report • Prepared by S Tejo Laakshman • 18 September 2026